

Rédaction du cadrage et de la note de stratégie

✓ Écrire pour durer : le cadrage, la feuille de route, et la première pierre de la stratégie

Objectifs de la séance

À l'issue de ce TP, le dossier MERIDIAN contient la note de cadrage du RSSI Groupe, la feuille de route pluriannuelle du groupe avec son cadre budgétaire, et la première sous-section de la note de stratégie. Ce qui s'y apprend :

- **Rédiger** une note de cadrage : le document qui délimite une mission avant qu'elle ne déborde
- **Construire** une feuille de route pluriannuelle dont les jalons engagent, adossée à un budget dont l'assiette est explicite
- **Distinguer** note de cadrage, feuille de route et note de stratégie, trois documents que les débutants fusionnent et que les directions veulent séparés
- **Poser** la première pierre du document enrichi à chaque séance et défendu en soutenance

Prérequis

- La gouvernance cible du TP précédent : instances, RACI, directives codifiées, règles d'arbitrage. Ce TP ne les réécrit pas, il les cite.
- L'analyse d'écarts et ses priorités : la feuille de route en est la mise en musique dans le temps.
- Le barème du module, présenté ce matin : la note de stratégie y pèse 10 points, et elle commence maintenant.

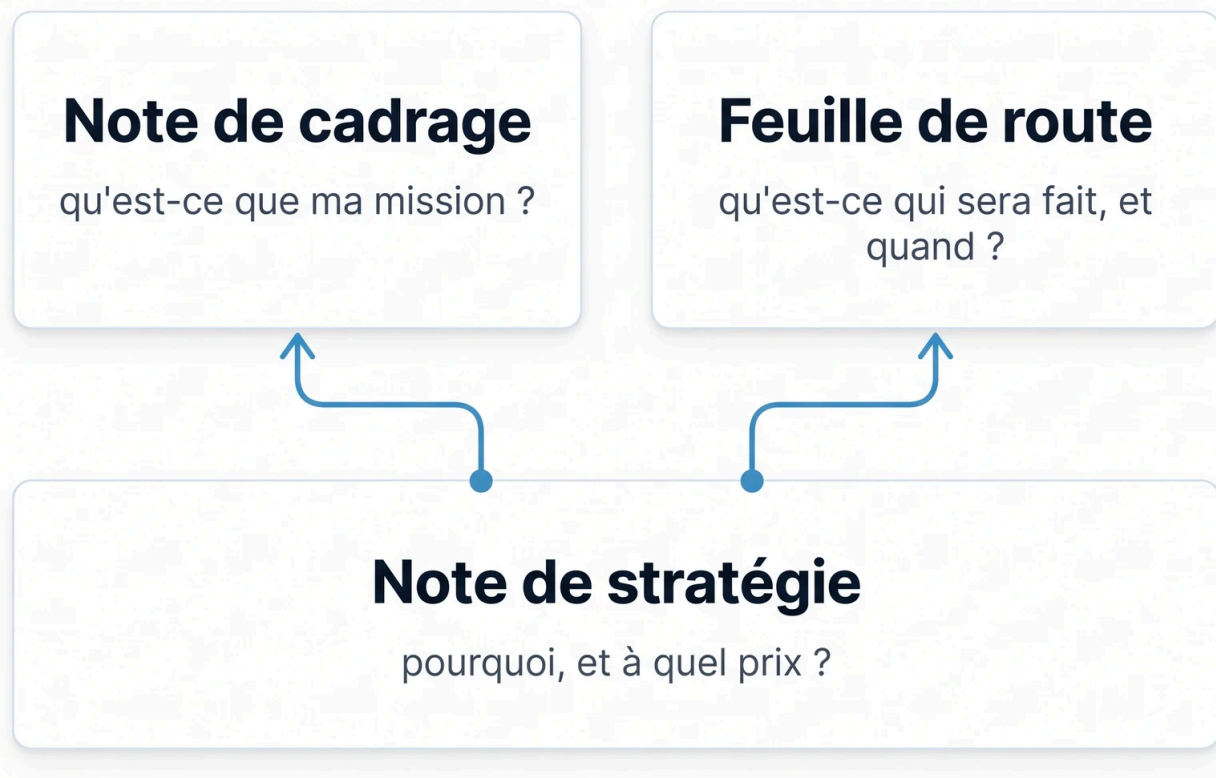
✓ Trois documents, trois fonctions, et l'erreur qui les confond

La note de cadrage, d'abord. Le problème qu'elle traite : une mission dont le périmètre n'est pas écrit enfile jusqu'à l'échec ; le RSSI Groupe qu'on n'a pas cadré se retrouve en six mois responsable de tout, coupable de tout, et décideur de rien. La note de cadrage est le document court qui délimite une mission : son objet, son périmètre, ses prérogatives, ses interlocuteurs, et ses limites, ce qu'elle ne couvre PAS. Sa mécanique la plus utile est justement cette dernière section : écrire ce qu'on ne fait pas est le seul rempart contre l'inflation des attentes. Sa limite : une note de cadrage décrit une mission, elle ne prouve pas qu'elle avance ; c'est le rôle des jalons, donc de la feuille de route.

La feuille de route, ensuite, avec son compagnon le **budget pluriannuel**. Le problème : la sécurité se construit sur des années, mais se budgète par exercices ; sans trajectoire écrite, chaque budget annuel repart de zéro, au gré des incidents récents et des humeurs. Une feuille de route pluriannuelle ordonne les chantiers dans le temps, avec des jalons datés et vérifiables ; le budget pluriannuel qui l'accompagne répartit l'effort entre les axes, et chaque répartition doit préciser son ASSIETTE, c'est-à-dire sur quelle enveloppe exacte portent les pourcentages, faute de quoi les chiffres se contredisent d'une réunion à l'autre. Le contexte s'y prête : d'après le baromètre du CESIN publié pour 2023, 63 % des entreprises prévoyaient une augmentation de budget allouée aux dispositifs de protection ; les moyens montent, ce qui rend l'arbitrage plus nécessaire, pas moins, car un budget qui grandit sans trajectoire finance les urgences, jamais les fondations. La limite du genre : une feuille de route à trois ans est une hypothèse, pas une prophétie ; elle se révisé, et c'est un jalon comme un autre.

La note de stratégie, enfin. Celle-ci a un statut à part dans le module, pour trois raisons. C'est un livrable noté, qui vaut 10 points au barème. C'est le document que la soutenance finale défendra tel quel. Et surtout, c'est un document cumulatif : trois pages au maximum, commencées aujourd'hui, puis enrichies quinze minutes à la fin de chaque après-midi jusqu'à la séance 10. Le problème qu'elle simule est très réel. Un RSSI tient pour sa direction un document de stratégie vivant : à chaque avancée du dossier, le document grandit, sans jamais être réécrit depuis le début. Savoir l'entretenir est une compétence professionnelle en soi : ajouter une sous-section sans toucher aux précédentes, corriger une affirmation devenue fausse sans en effacer la trace. D'où la règle d'or du module, vérifiée à chaque séance : rien ne se supprime jamais dans la note de stratégie ; ce qui doit changer s'amende, et chaque amendement s'accompagne d'une phrase qui explique pourquoi.

💡 Le test qui départage les trois documents : le cadrage répond à « qu'est-ce que ma mission ? », la feuille de route à « qu'est-ce qui sera fait, et quand ? », la stratégie à « où allons-nous, et pourquoi ? ». Une phrase qui répond à une autre question que celle de son document est au mauvais endroit.



Elle cite les deux autres, elle ne les duplique jamais

✓ Exercice 1 : la note de cadrage du RSSI Groupe (15 minutes)

C'est le document qui aurait dû exister avant le premier lundi du RSSI Groupe. Une page, cinq sections.

1. **Rédiger** la note de cadrage de la mission du RSSI Groupe : l'objet (pourquoi ce poste existe, en deux phrases ancrées dans la situation du groupe) ; le périmètre (les quatre filiales, le pôle à DSI mutualisée, les flux inter-filiales) ; les prérogatives (citer les trois règles d'arbitrage de la gouvernance cible, sans les réécrire) ; les interlocuteurs (les instances du matin, chacune avec ce qui lui est dû : proposition, compte rendu, alerte) ; et les limites.
2. **Soigner** la section des limites : trois exclusions au moins, réalistes et utiles (indice : la posture RSSI du matin ; ce que le RSSI n'a PAS le droit de faire à la place des autres est le meilleur point de départ).

✓ Exercice 2 : la feuille de route et son budget (15 minutes)

La Direction Générale a arrêté le principe d'une trajectoire de trois ans, découpée en six semestres, pour porter le groupe à la gouvernance cible ; le RSSI Groupe la présentera, avec son cadre budgétaire, au premier Comité de Direction, dans trois mois. Trois axes stratégiques sont retenus avec elle pour le groupe : le socle de confiance, la résilience OT/IT, et la culture sécurité.

1. **Construire** la feuille de route : pour chaque semestre, un objectif principal, et trois jalons vérifiables aux échéances de 12, 24 et 36 mois, en cohérence avec les priorités 1 et 2 de l'analyse d'écarts (indice : ce qui est vrai à 12 mois conditionne le jalon de 24).
2. **Proposer** la pondération budgétaire des trois axes, en pourcentage, avec une ligne de justification par axe, et en PRÉCISANT l'assiette de chaque chiffre avancé.
3. **Trancher** deux arbitrages soumis par la direction : les filiales Santé et Éducation demandent chacune un renforcement immédiat, sur une enveloppe exceptionnelle dégagée à budget constant, par redéploiement entre filiales puisque la DG n'accorde aucun budget nouveau la première année, et qui ne peut servir qu'elles deux ; et une part des enveloppes existantes doit être réallouée vers la modernisation des infrastructures obsolètes, dont la proposition est attendue. Justifier le premier chiffre par un élément du dossier, le second par un indicateur du tableau de bord construit au TP précédent.

✓ Note de stratégie (15 minutes)

Le rituel commence ici, et il ne s'arrêtera qu'à la soutenance. La note de stratégie s'ouvre aujourd'hui avec sa première sous-section : « Contexte et gouvernance cible ». Une demi-page au plus, et trois contenus seulement : le contexte, ce qu'est le groupe et pourquoi la sécurité y devient une affaire de gouvernance, en s'appuyant sur ce que la journée a établi sans le redérouler ; la gouvernance cible, les instances, la RACI et les règles d'arbitrage, citées en renvoi vers la charte, jamais recopiées ; et l'engagement de trajectoire, la déclinaison de la PSSI cadre par chaque filiale sous six mois, premier jalon opposable de la feuille de route.

Deux disciplines à prendre dès cette première fois, car elles seront notées jusqu'au bout : la note de stratégie renvoie aux documents du dossier, elle ne les duplique jamais, c'est ce qui lui permettra de tenir en trois pages dans neuf séances ; et chaque affirmation doit rester vraie dans la durée ou être amendable d'une phrase, car rien ne se supprime.

Et pour clore la séance, la phrase qui la transmet : la gouvernance écrite dans l'heure décide désormais QUI arbitre et selon quelles règles ; ce qui lui manque encore, c'est de savoir exactement SUR QUOI elle règne, et c'est l'objet de la prochaine séance, la cartographie du système d'information du groupe, sans laquelle chaque décision de la charte s'appliquerait à un territoire inconnu.

🔗 Corrigés et critères d'évaluation

Corrigé de l'exercice 1 : la note de cadrage de référence, sur TRAMONTANE

Le modèle de référence, à comparer après coup, est pris hors dossier pour ne pas donner la réponse : la note de cadrage du RSSI de TRAMONTANE, l'enseigne fictive de vente en ligne d'équipement de plein air qui sert d'exemple au module, avec sa société sœur TRAMONTANE Ateliers, qui contrôle, remet en état et remet en vente les articles retournés. Le cas est plus petit que MERIDIAN, une entreprise et sa société sœur au lieu de quatre filiales, et c'est voulu : ce qui se compare, c'est la forme de chaque section, pas son contenu. La note tient en une page et en cinq sections :

- **Objet.** TRAMONTANE a créé le poste de RSSI parce que la totalité de ses ventes passe par un site marchand hébergé chez un prestataire et par un entrepôt piloté par un logiciel qu'elle n'édite pas, et que personne ne répondait de la sécurité de cette chaîne : la DSI de douze personnes la faisait fonctionner, la direction commerciale la vendait, aucune des deux ne décidait. Le poste existe pour qu'une seule fonction propose les règles, arbitre les écarts et en rende compte à la direction générale.
- **Périmètre.** Le site marchand et sa base de commandes, l'entrepôt de Rivesaltes et son logiciel de gestion d'entrepôt, les échanges de données avec le prestataire de paiement et le transporteur, et la frontière avec TRAMONTANE Ateliers, dont les retours transitent par le même site marchand. Hors périmètre, et écrit tel quel : le système d'information propre d'Ateliers, qui relève du responsable de l'atelier de reconditionnement.
- **Prérogatives.** Celles de la charte de sécurité de l'enseigne, citées en renvoi et jamais réécrites : l'avis de sécurité préalable à toute mise en production du site marchand et à tout nouvel échange de données avec un tiers, rendu sous cinq jours ouvrés, passé lesquels la mise en production a lieu ; le droit de suspendre un échange de données avec un tiers en cas de compromission avérée, la direction générale étant informée dans l'heure ; et la validation des dérogations à la charte, accordées pour un trimestre au plus et renouvelées seulement par écrit. Trois mécanismes différents de ceux de MERIDIAN, choisis pour une entreprise où la mise en production hebdomadaire du site est le rythme du métier.
- **Interlocuteurs.** La direction générale, à qui le RSSI propose la charte, ses révisions et le niveau de risque accepté ; le comité de direction mensuel, où il rend compte des écarts, des incidents et des dérogations en cours ; le DSI, le responsable de l'équipe web et le directeur de l'entrepôt, qu'il consulte avant toute règle qui touche leur exploitation ; le responsable du service client, qu'il informe de tout incident qui touche les données clients ; le responsable de l'atelier de reconditionnement de TRAMONTANE Ateliers, qu'il alerte sur tout incident du site marchand partagé ; et le prestataire de paiement, dont il reçoit les exigences contractuelles et à qui il doit une réponse documentée.
- **Limites.** Quatre exclusions, écrites : le RSSI ne fixe pas le niveau de risque que l'enseigne accepte, il le propose à la direction générale, qui le fixe ; il n'administre ni le site marchand ni le logiciel d'entrepôt, l'exploitation reste à la DSI et à l'hébergeur dans les termes de son contrat ; il ne négocie pas les contrats avec les prestataires, il y fait inscrire les exigences de sécurité et en vérifie la tenue ; il ne se

substitue pas au responsable de l'atelier de reconditionnement pour la sécurité du système d'information de TRAMONTANE Ateliers, il ne répond que de ce qui traverse la frontière entre les deux sociétés.

Ce qui se transpose à MERIDIAN n'est pas une ligne de cette note, c'est sa mécanique : un objet en deux phrases qui dit le manque auquel le poste répond ; un périmètre qui nomme ce qui est dedans, ce qui est dehors, et la frontière entre les deux ; des prérogatives citées en renvoi vers les règles d'arbitrage écrites le matin, avec leurs délais, sans les réécrire ; des interlocuteurs nommés un par un, chacun avec ce qui lui est dû, proposition, compte rendu, consultation ou alerte ; et des limites qui disent ce que le RSSI ne fait pas à la place des autres. Une note MERIDIAN qui reprendrait le périmètre ou les prérogatives de TRAMONTANE serait hors sujet : le groupe a quatre filiales, un pôle à DSI mutualisée et trois règles d'arbitrage qui lui sont propres.

La note tenait-elle en une page ? C'est aussi un critère : un cadrage long est un cadrage qui n'a pas choisi.

Corrigé de l'exercice 2 : la trajectoire de référence

La feuille de route du groupe : trois ans, six semestres, dont une phase prioritaire de 24 mois qui concentre l'essentiel de l'effort, les 12 derniers mois consolidant et préparant la suite. Les trois jalons :

Échéance	Jalons vérifiables
12 mois	Les écarts de priorité 1 traités : cloisonnement du biomédical de Santé engagé, séparation des comptes du prestataire de Logistique achevée. PSSI cadre déclinée par les quatre filiales, l'engagement de six mois laissant six mois de marge de vérification.
24 mois	Segmentation IT/OT de Logistique opérationnelle. Journalisation de Territoires centralisée vers le SOC. Tableau de bord exécutif alimenté sans collecte manuelle.
36 mois	Gouvernance cible pleinement appliquée et mesurée, réserve faite de la révision de trajectoire, qui est elle-même un jalon.

La pondération de référence des axes. Assiette : le budget sécurité pluriannuel du groupe, que la feuille de route consolide à partir des lignes aujourd'hui noyées dans les budgets d'exploitation des filiales, à montant constant la première année.

Axe	Part	Justification
Socle de confiance	40 %	Identités, accès et authentification portent les deux priorités 1.
Résilience OT/IT	35 %	Le cœur industriel de Logistique et le biomédical de Santé.
Culture sécurité	25 %	L'investissement le plus lent et le plus durable.

Les deux arbitrages attendus :

- **L'enveloppe exceptionnelle.** Assiette : l'enveloppe dégagée à budget constant, limitée à Santé et Éducation, donc sans budget nouveau la première année comme la DG l'exige : 60 % pour Santé, 40 % pour Éducation. La mission de soin et l'état du biomédical pèsent plus lourd que l'exposition, réelle mais moins vitale, du parc Éducation.
- **La réallocation vers la modernisation.** 15 % des enveloppes existantes vers les infrastructures obsolètes, adossée au KRI d'obsolescence du tableau de bord, dont le seuil d'alerte justifie précisément que l'on désinvestisse ailleurs.

La grammaire commune des deux réponses : chaque chiffre porte son assiette et sa justification. Un pourcentage nu n'est pas un arbitrage, c'est une opinion en costume.



Corrigé : la sous-section « Contexte et gouvernance cible », rédigée en modèle sur TRAMONTANE

Même principe que pour la note de cadrage : le modèle est écrit pour TRAMONTANE, pas pour MERIDIAN, et c'est sa construction qui se compare, pas ses phrases.

« TRAMONTANE, enseigne de vente en ligne d'équipement de plein air, vend et livre par une chaîne dont elle ne maîtrise aucun maillon en propre : un site marchand hébergé chez un prestataire, un entrepôt à Rivesaltes piloté par un logiciel tiers, un prestataire de paiement, un transporteur relié par échange de données, et une société sœur, TRAMONTANE Ateliers, dont les retours transitent par le même site. L'enseigne s'est dotée d'une gouvernance de sécurité écrite : une direction générale qui fixe le niveau de risque accepté, un comité de direction mensuel qui en suit les écarts, un RSSI unique qui propose, arbitre et rend compte, et trois règles d'arbitrage rassemblées dans la charte de sécurité à laquelle la présente note renvoie. Cette gouvernance répond au constat de la note de cadrage jointe au dossier : une chaîne dont personne ne répondait de bout en bout. Chacun des trois prestataires de la chaîne voit les exigences de sécurité de l'enseigne inscrites à son contrat, et TRAMONTANE Ateliers signe une convention de sécurité sur ce qui traverse la frontière, le tout sous six mois ; ces cinq signatures constituent le premier jalon de la feuille de route de trois ans validée dans son principe par le comité de direction. »

Trois phrases longues ou cinq courtes, peu importe : contexte, renvoi aux documents, engagement daté. Rien à supprimer plus tard, tout amendable. Ce qui se transpose à MERIDIAN, ce sont ces trois contenus dans cet ordre, pas une phrase du modèle : un groupe à quatre filiales ne se décrit pas comme une enseigne à trois prestataires, et son engagement de trajectoire, celui de l'énoncé, ne porte pas sur des contrats.

Critères d'évaluation

Critère	Insuffisant	Attendu	Excellent
Note de cadrage	Mission décrite sans limites ni interlocuteurs	Cinq sections, prérogatives citées en renvoi	Les limites protègent réellement la posture : ne fixe pas, n'administre pas, ne se substitue pas
Feuille de route	Jalons vagues ou non datés	Trois jalons vérifiables à 12, 24, 36 mois, cohérents avec les priorités	Idem, avec la dépendance entre jalons explicitée et la révision traitée comme un jalon
Budget	Pourcentages sans assiette ni justification	Pondérations justifiées, assiettes précisées partout	Idem, les deux arbitrages adossés à des éléments du dossier (mission, KRI)
Note de stratégie	Recopie des documents du dossier	Une demi-page, trois contenus, renvois plutôt que duplications	Idem, chaque affirmation durable ou amendable d'une phrase
Transmission	Absente	Le lien vers la cartographie de la prochaine séance formulé	Idem, articulé : une gouvernance sans carte règne sur un territoire inconnu